TECHNICAL ARCHITECTURE · IMPLEMENTATION PLAN

DPP-Industrial

Calibration Passport for ISO-17025 Industrial Measurement Equipment

A tokenless verifiable-credential infrastructure for EU ESPR Digital Product Passport compliance and the EU Machinery Regulation 2027.

David Schmitt

Version 0.1 · May 2026 · Working Draft

Contents

1. Executive Technical Summary
2. Architectural Principles
3. System Architecture Overview
4. Layer Deep Dives

   4.1 Chain 4.2 Storage 4.3 Identity 4.4 Attestation 4.5 Credentials 4.6 ZK / Privacy 4.7 Registry 4.8 Data Carrier 4.9 API Gateway
5. Data Model
6. API Architecture

   6.1 Issuer API 6.2 Holder API 6.3 Verifier API 6.4 Internal Services 6.5 EUDI Wallet
7. Critical Flows (five end-to-end flows with sequence diagrams)
8. Security Architecture and GDPR
9. Implementation Roadmap (five MVPs over 30 months)
10. Tech Stack Reference
11. Open Technical Questions

Appendix A — Cost Model per Asset Lifecycle

Diagram Index

Fig. 1 — System Overview · Fig. 2 — Tech Stack · Fig. 3 — Physical Trust Anchor
Fig. 4 — Data Model ER · Fig. 5 — Flow 1 Onboarding · Fig. 6 — Flow 2 Calibration
Fig. 7 — Flow 3 Verification · Fig. 8 — Implementation Roadmap

1. Executive Technical Summary

What we are building. DPP-Industrial is a tokenless verifiable-credential infrastructure for industrial measurement equipment that addresses both the EU ESPR Digital Product Passport mandate (Central Registry live 19 July 2026, vertical mandates rolling from 2027 to 2030) and the EU Machinery Regulation 2027 (digital documentation requirement). Concretely: an NFC- and QR-based identity anchor that gives every asset a lifelong, cryptographically signed record (pedigree, conformity, calibration, maintenance, ownership, recycling) from manufacturer to recycler.

What the stack is. A nine-layer architecture combining EAS attestations and ERC-5192 soulbound tokens on Base L2 with W3C Verifiable Credentials 2.0, encrypted dual-storage on Filebase and Arweave, mobile-grade zero-knowledge proofs through Noir and Mopro, and integration into the EU Central DPP Registry via the CIRPASS-2 schema family. The two DPP-specific layers are the EU Registry connector and the GS1 Digital Link data carrier; the others are general-purpose verifiable-credential infrastructure.

Construction principles. Five non-negotiable principles structure every architectural decision: (1) tokenless by design — soulbound, non-transferable, GDPR- and MiCA-aligned; (2) off-chain payloads, on-chain hashes only — GDPR fine avoidance; (3) issuer is always a real-world authority — manufacturer, accredited lab, notified body, never the platform itself; (4) EU Registry compatibility, not substitution — we register, we do not replace; (5) selective disclosure as default, full disclosure is opt-in.

What this document is. A technical specification at a depth sufficient for a CTO co-founder, a technical due-diligence reviewer, or a public-funding application (EIC, EXIST) to use as an implementation foundation. It contains the system architecture, layer-by-layer deep dives, the complete data model, the API specification, three critical end-to-end flow diagrams, the security and GDPR architecture, a 30-month five-MVP implementation plan, and an honest register of open technical questions.

What it is not. Not a whitepaper. Not marketing material. Not a grant application (although large portions of the content would transfer there). This specification is at a level of implementation detail deliberately higher than investor materials — because that is what the person who will actually build the system needs.

> **HEADLINE NUMBER** *Estimated on-chain plus storage cost per asset lifecycle: 0.50–0.70 USD. At 50,000 assets per year in the scale MVP, that is 25,000–35,000 USD of annual infrastructure cost — negligible compared with engineering and governance.*

2. Architectural Principles

Five principles structure every downstream decision. They are what an architecture review should defend first, and what must be documented explicitly whenever a later decision deviates.

2.1 Tokenless by Design

At no point is a fungible or transferable token issued. The only on-chain token is ERC-5192 (soulbound), i.e. **permanently non-transferable**. Rationale: (a) GDPR — transferable tokens trigger more complex joint-controller scenarios; (b) MiCA — Recital 11 grants a categorical carve-out for non-fungible soulbound tokens, while transferable tokens would fall under CASP licensing; (c) reputation — the industrial buyer audience (plant managers, compliance officers, accredited calibration labs) is unreceptive to token communication after the visible failure of consumer-facing tokenization projects. Branding language: **"Verified Asset Records," "tamper-proof calibration,"** never "blockchain," "token," or "Web3."

2.2 Off-Chain Payloads, On-Chain Hashes

Personal or commercially sensitive data never appears on chain. On chain there are only (a) hashes of off-chain stored payloads, (b) schema hashes, (c) issuer DIDs, (d) expiration and revocation status. Rationale: **EDPB Guidelines 02/2025** — "technical impossibility cannot be invoked to justify non-compliance." Cryptographic deletion (key destruction) functionally satisfies Art. 17 GDPR and is tolerated by the EDPB although not yet judicially confirmed.

2.3 Issuer = Real-World Authority

An attestation has only the trust value of its issuer. The platform is never the issuer of substantive claims. It is infrastructure. Concretely: ConformityAttestations are signed by notified bodies (TÜV, DEKRA), CalibrationAttestations by DAkkS-accredited labs, ManufactureAttestations by the manufacturer. Each of these issuers has an established reputation, an accreditation trust anchor, and a working business model. The architecture amplifies that trust; it does not replace it.

2.4 EU-Registry-Compatible, Not a Substitute

The EU Central DPP Registry goes live on 19 July 2026 and is mandatory for economic operators (with a Backup DPP Service obligation per ESPR Art. 9). The architecture **complements** the Registry; it does not replace it. Every asset is registered there (legal obligation) and additionally verifiably attested on chain (added value). The on-chain record is an extension of the official registration, not a parallel competing identity. This pattern of extending the official document is conventional across regulated identity systems and avoids any legal-substitution risk.

2.5 Selective Disclosure as Default

Every verifier query is by default mediated through selective disclosure (SD-JWT) or a zero-knowledge proof. An insurer wanting to verify the validity of a calibration does not receive the full calibration report — but the proof that the most recent calibration is not older than twelve months and the measurement uncertainty is below 0.5 percent. Full disclosure is explicitly opt-in by the holder. This is not only GDPR-elegant; it also creates a verifier-API revenue model (see Section 6).

3. System Architecture Overview

The system consists of three actor classes (issuer, holder, verifier), one API gateway, five core services, a physical trust anchor (NFC plus QR), and four external integrations (EU Registry, EUDI Wallet, GS1 Resolver, storage providers). The chain layer (Base L2) and the EAS smart contracts form the central anchor; all business logic lives off-chain in the services — on chain only hashes and identity anchors.

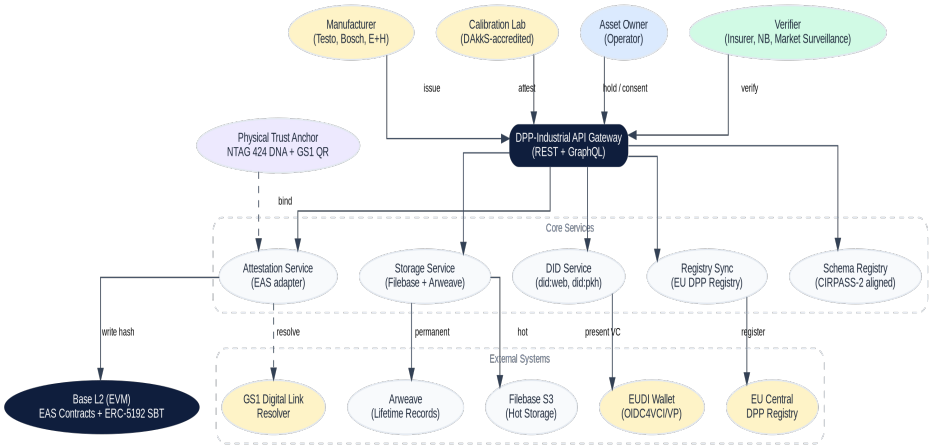

Figure 1 — System overview. Actors (top), API gateway, core services (middle), physical trust anchor (left), and external systems (bottom).

Separation of concerns. The API gateway is the sole ingress and egress point. It handles authentication, authorization, rate limiting, audit logging, and schema validation. The core services are initially implemented as a modular monolith (see MVP plan in Section 9.3), not as distributed microservices, because the complexity overhead is not justified for a team of two to four engineers during the first eighteen months.

3.1 Layered Stack

Nine layers from chain to application. Two layers (EU Registry Sync and Data Carrier) are DPP-specific; the remaining seven are general-purpose verifiable-credential infrastructure that other industries could share.

Layered Architecture — 9 Layers, Production-Ready 2026

9. Application Layer	Issuer Portal · Owner Mobile App · Verifier Console	
8. API Gateway	REST + GraphQL · OIDC4VCI/VP · Webhooks	
7. Data Carrier	GS1 Digital Link · QR · NFC NTAG 424 DNA · RFID (optional)	*DPP-SPECIFIC*
6. EU Registry Sync	EU Central DPP Registry connector · Backup DPP Service	*DPP-SPECIFIC*
5. ZK / Privacy	Noir circuits · Mopro mobile prover · SD-JWT selective disc.	
4. Credentials	W3C VC 2.0 (final 2025) · EBSI/EUDI compatible	
3. Attestations / Identity	EAS on Base · ERC-5192 SBT · did:web (Issuer) · did:pkh (Holder)	
2. Storage	Filebase (hot S3) · Arweave + Bundlr (permanent)	
1. Chain	Base L2 (OP-Stack) · Coinbase Smart Wallet (Passkey, no-seed)	

Two layers (EU Registry Sync, Data Carrier) are DPP-specific; the others are general-purpose verifiable-credential infrastructure.

Figure 2 — Layered architecture. Layers 6 and 7 are the DPP-specific components.

4. Layer Deep Dives

This chapter describes each layer in order from bottom (chain) to top (application). Every section names the implementation library, the design trade-offs, and at least one alternative that was deliberately not chosen.

4.1 Chain Layer — Base L2

Choice: Base (Coinbase L2, OP-Stack). **Rationale:** Lowest transaction fees among production-grade L2s (0.01–0.05 USD per EAS attestation), native EAS deployment since 2024, Coinbase Smart Wallet with Passkey authentication (no seed phrase, no wallet-onboarding burden for fifty-year-old plant technicians). **Alternatives considered:** Polygon zkEVM (fee volatility, less mature EAS integration), Arbitrum (higher fees, no native smart-wallet equivalent), Optimism (comparable, but Base has the larger EU compliance and identity ecosystem through Coinbase Verifications).

> **MIGRATION RISK** *Should Base be discontinued or captured, migration to other OP-Stack chains is feasible in four to eight weeks (same EVM semantics, same EAS contract code). Existential risk is low.*

4.2 Storage Layer

Two parallel storage backends: **Filebase** (S3-API-compatible IPFS provider, three-way geo-redundant, 0.06 USD per GB per month) for hot storage of frequently accessed payloads such as active calibration reports, and **Arweave plus Bundlr** for lifetime storage (pay-once model, approximately 0.007 USD per MB, guaranteed persistence over twenty-plus years). Every payload is written to both backends; the on-chain hash is backend-agnostic.

Encryption: AES-256-GCM with a per-asset key. Keys are managed in the manufacturer HSM and released to holders and verifiers only through capability delegation. Cryptographic-deletion path: key destruction functionally satisfies Art. 17 GDPR even though the encrypted blob remains persistent.

4.3 Identity Layer — DIDs

Two DID methods: **did:web** for institutional issuers (manufacturers, calibration labs, notified bodies). Pragmatic: a DID like `did:web:testo.com` is resolvable over HTTPS, anchored to the established domain reputation, and requires no separate method spec. **did:pkh** (Public Key Hash) for individual holders — a DID is derived directly from the wallet address, without separate registration. This eliminates the ENS-registration friction for non-technical asset owners.

4.4 Attestation Layer — EAS + ERC-5192

EAS (Ethereum Attestation Service) has been live on Base since 2023, is intensively used by Coinbase Verifications and Gitcoin Passport, is token-free (Public Good), and provides the generic primitive “X

attests to Y about Z" with a schema registry, revocation, and resolver pattern for business logic. **ERC-5192** complements this primitive with a soulbound token per asset as a wallet-visible anchor — important because holders want to see their asset in a wallet, and EAS attestations alone are not natively wallet-renderable.

Alternative considered: Pure Verifiable Credentials without EAS (classical SSI stack). Rejected because EAS attestations are on-chain composable — a Calibration attestation can reference a Conformity attestation (via refUID), which in turn references a Manufacture attestation. This trust chain can be reconstructed only off-chain with pure VCs, which weakens verifier-side guarantees.

4.5 Credentials Layer — W3C VC 2.0

For consumer- and regulator-facing documents (CE Declaration of Conformity, calibration certificate) we additionally emit **W3C VC 2.0** as a data format (W3C-final 2025). This is EBSI/EUDI-Wallet compatible — critical for EU Registry onboarding from 2027 and for EUDI-Wallet integration from 2027. **SD-JWT-VC** for selective disclosure: a calibration certificate can be presented such that only "valid for the next twelve months" is visible, without disclosing the full measurement-uncertainty report.

4.6 Privacy / ZK Layer

Noir (Aztec, a Rust-like DSL) as the circuit language, **Mopro** as the mobile prover runtime. Practical use cases: (a) calibration is valid for at least N months without disclosing the date, primary insurer use case; (b) asset belongs to the registered fleet without disclosing owner identity, market-surveillance use case; (c) asset conforms to standard X without disclosing the notified-body identity. Mobile proofs run in 2–8 seconds on modern smartphones (FibRace September 2025 benchmark).

> **TRUSTED SETUP** *Noir uses PLONK-style universal setup — no per-circuit trusted setup is required. That saves an estimated 50–150 k€ in audit and ceremony costs per circuit compared with Groth16-based stacks.*

4.7 EU Registry Sync Layer

The EU Central DPP Registry goes live on 19 July 2026. The final API specification is still in CIRPASS-2 consultation as of May 2026, but the underlying model is clear: every asset receives a Registry record with (a) manufacturer DID, (b) product ID (GTIN), (c) serial number, (d) URI to the DPP service. The backend synchronizes on asset onboarding and on status changes. Crucially, **ESPR Art. 9** requires a "Backup DPP Service" — if the primary service becomes unavailable, a second provider (typically a national consortium) must continue to expose the DPP. This must be contractually resolved before MVP 3.

4.8 Data Carrier Layer

GS1 Digital Link (ISO/IEC 18975) as the URL format on the asset. A URL such as `https://id.gs1.org/01/04012345678905/21/SN12345` encodes GTIN and serial number and is resolved by the GS1 Resolver network to the DPP service URI. Implemented in parallel over NFC (NTAG 424 DNA) and QR code — NFC for the field-technician workflow (taps with phone) and QR for visual verification and as a backup where no NFC reader is available.

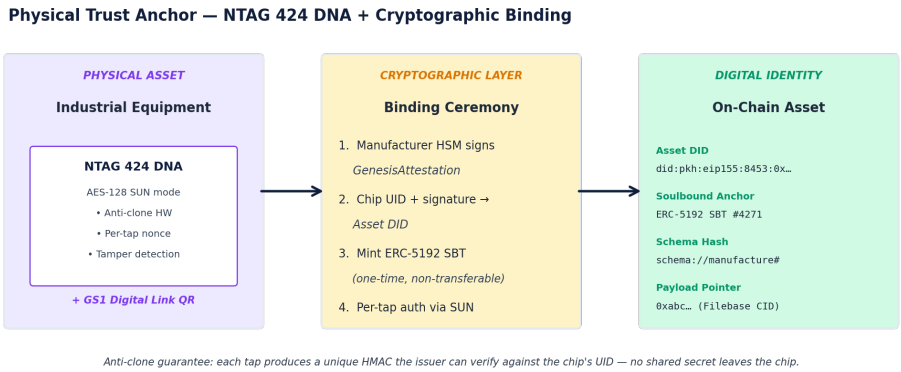

Figure 3 — Physical trust anchor. Three tiers: asset (NTAG 424 DNA plus GS1 QR), cryptographic binding ceremony, on-chain asset anchor.

Why NTAG 424 DNA specifically: It is the only consumer-priced NFC chip with an AES-128 hardware key in a secure element that delivers a per-tap encrypted counter and HMAC, making it clone-resistant. Plain ISO-11784/85-class tags common in industrial inventories are **not** cryptographically protected and are clonable in under a minute with commodity hardware. The binding between physical asset and digital identity, often the weakest link in such systems, is therefore reduced to a hardware guarantee. Chip cost: 0.30–1.50 USD depending on volume and encapsulation.

4.9 API Gateway and Application Layer

REST-based API gateway (no gRPC initially — integration partners such as insurers, notified bodies, and PMS vendors expect REST). GraphQL only internally between services. OIDC4VCI/VP endpoints for EUDI-Wallet integration. Auth: **mTLS** for manufacturer API clients (institutional, fixed-roster connections), **OAuth 2.0 plus DID-based JWT** for the verifier API (dynamic third parties). Application layer: three separate frontends — Issuer Portal (web), Owner Mobile App (iOS plus Android, React Native), Verifier Console (web plus a mobile companion app for market-surveillance staff).

5. Data Model

The data model is an asset-centric star: a root Asset entity referenced by six attestation types. All attestations are registered on Base via EAS schema UIDs; full payloads live off-chain in Filebase plus Arweave. Each attestation references its predecessor in the asset history via refUID — producing a cryptographically linked, always-verifiable lifecycle chain.

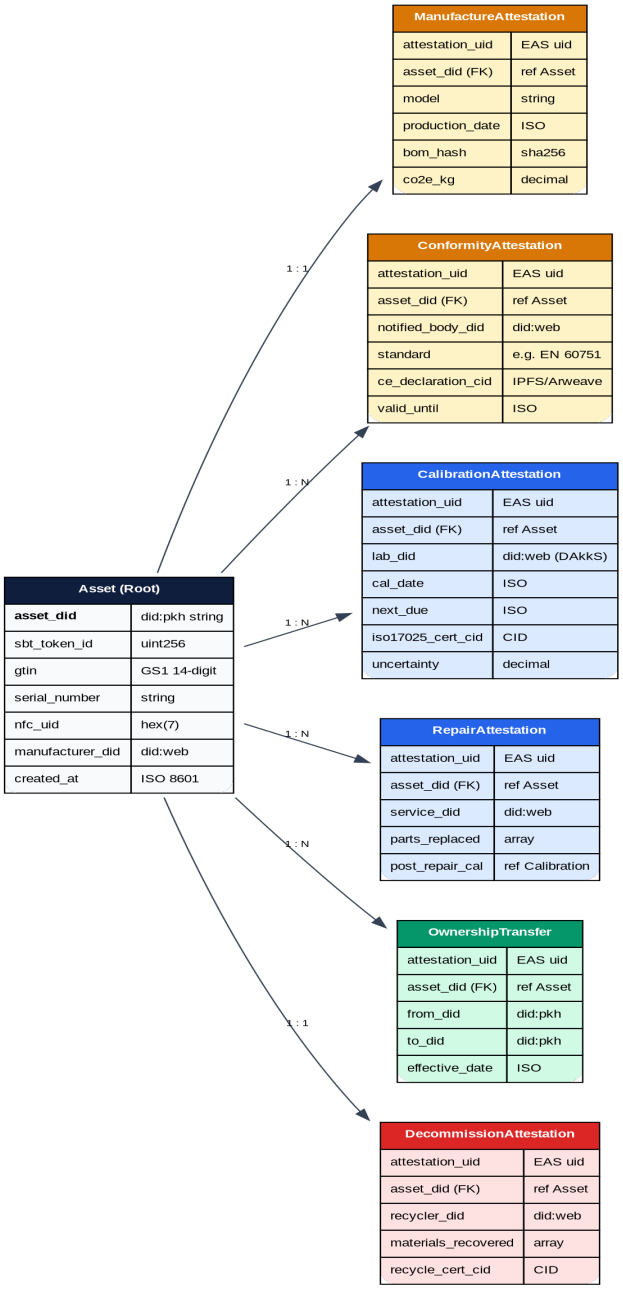

Figure 4 — Data model. Asset as root, six attestation types with referential linkage.

5.1 Schema Registry

Each attestation type is registered as an **EAS schema**. The schema defines the on-chain structure (fields plus types); the off-chain payload is referenced by hash. CIRPASS-2 Core Ontology mapping: our schemas are modeled as an extension of CIRPASS-2 base schemas so that future standardization does not require a schema rewrite.

5.2 Example Schema: CalibrationAttestation

The most important schema for the industrial wedge — calibrations are the most frequent lifecycle event and the primary B2B value contribution. Full schema definition:

```
// EAS Schema (on-chain, immutable after registration)
schema CalibrationAttestation {
    bytes32 assetDid;            // refers to root Asset SBT
    bytes32 labDid;              // did:web of accredited lab
    uint64  calDate;             // unix timestamp
    uint64  nextDueDate;
    bytes32 isoCertCid;          // off-chain ISO 17025 cert pointer
    bytes32 payloadCid;          // full calibration report (encrypted)
    bytes32 payloadHash;         // sha256 of unencrypted report
    uint32  uncertaintyMicro;    // measurement uncertainty * 1e6
    uint8   status;              // 0=valid, 1=revoked, 2=superseded
}

// Off-chain payload (W3C VC 2.0, encrypted at rest)
{
  "@context": ["https://www.w3.org/ns/credentials/v2"],
  "type": ["VerifiableCredential", "CalibrationCredential"],
  "issuer": "did:web:dakks-lab-12345.de",
  "validFrom": "2026-05-15T08:30:00Z",
  "validUntil": "2027-05-15T08:30:00Z",
  "credentialSubject": {
    "id": "did:pkh:eip155:8453:0xabc...",
    "assetType": "Thermometer testo 175 H1",
    "standard": "EN 60751",
    "measurementPoints": [
      { "nominal": -20.0, "actual": -19.87, "uncertainty": 0.12 },
      { "nominal":   0.0, "actual":  -0.03, "uncertainty": 0.08 },
      { "nominal":  50.0, "actual":  50.04, "uncertainty": 0.09 },
      { "nominal": 100.0, "actual": 100.11, "uncertainty": 0.11 }
    ],
    "ambientConditions": { "temp": 23.1, "humidity": 47 },
    "labAccreditation": "D-K-15012-01-00"
  },
  "proof": { "type": "DataIntegrityProof", "cryptosuite": "eddsa-rdfc-2022", ... }
}
```

5.3 Lifecycle Chaining via refUID

Each new attestation references its predecessor via the native EAS `refUID` field. A RepairAttestation references the immediately preceding CalibrationAttestation and typically triggers a new CalibrationAttestation. This produces a deterministic, cryptographically linked asset history reconstructible by a simple EAS query:

```
// Pseudocode: reconstruct asset history
function getLifecycle(assetDid) {
    let attestations = EAS.queryByRefUID(assetDid);
    return attestations.sort((a, b) => a.timestamp - b.timestamp);
}
```

5.4 Schema Versioning

EAS schemas are immutable after registration. Schema versioning is handled via **schema forks**: a v2 schema is registered as a new schema, and the original v1 entry remains valid for historical attestations. Migration path: v1 attestations are mapped as legacy v1 in verifier code; new attestations target v2. This decouples operational data evolution from smart-contract upgrades — the latter remain rare and painful by design.

6. API Architecture

Three actor classes, three API surfaces. All three share the same gateway, but authentication and rate-limit profiles differ substantially.

6.1 Issuer API

Consumed by manufacturers (bulk onboarding), calibration labs (event-based), notified bodies (conformity audits), and recyclers (end-of-life). Auth: mTLS with client certificate bound to the issuer's did:web. Rate limit: 1,000 attestations per hour per issuer in MVP 2, 10,000 per hour from MVP 3 onward, scaled with manufacturer volumes.

Endpoint	Description	Auth
`POST /v1/assets`	Onboard a new asset — mints the SBT, writes the genesis attestation, registers in the EU Registry.	mTLS
`POST /v1/attestations`	Generic endpoint for any subsequent attestation (Calibration, Repair, Conformity, etc.).	mTLS
`POST /v1/attestations/{uid}/revoke`	Revoke a previously issued attestation (e.g. erroneous calibration).	mTLS
`GET /v1/assets/{did}/lifecycle`	Full lifecycle history (only for the issuer's own assets).	mTLS
`POST /v1/webhooks`	Subscribe to asset events (e.g. ownership transfer to a recycler).	mTLS

6.2 Holder API (Owner Mobile App)

Consumed by the owner wallet (Coinbase Smart Wallet integrated, custom mobile app). Auth: **Passkey plus wallet signature** — no username or password. Strict rate limits (60 requests per minute per wallet); end-user traffic is typically low volume.

Endpoint	Description	Auth
`GET /v1/owner/assets`	All assets associated with the wallet address (via OwnershipTransfer attestations).	Passkey-JWT
`POST /v1/owner/disclose`	Issue selective disclosure — generates SD-JWT-VP for a specific verifier.	Passkey-JWT
`POST /v1/owner/transfer`	Initiate ownership transfer — requires the recipient's co-signature.	Passkey-JWT

Endpoint	Description	Auth
`POST /v1/owner/zk-proof`	Generate ZK proof (e.g. “calibration valid” without revealing the underlying data).	Passkey-JWT

6.3 Verifier API

Consumed by insurers, market-surveillance authorities, auditors, and service partners. Auth: **OAuth 2.0 with DID-bound JWT**. Verifiers do not need to onboard; they can scan a QR code and immediately read the public asset data. A consent flow to the holder is built in for sensitive data (see Flow 3, Section 7.3).

Endpoint	Description	Auth
`GET /v1/verify/resolve`	GS1 Digital Link resolution — returns the DPP URI and public header.	Public (rate-limited)
`GET /v1/verify/asset/{did}`	Public asset metadata plus a list of available attestation types.	Public
`POST /v1/verify/request-disclosure`	Request selective disclosure from the holder (asynchronous, via webhook).	OAuth + DID-JWT
`POST /v1/verify/zk-verify`	Verify a ZK proof (insurer use cases).	OAuth + DID-JWT

6.4 Internal Services

Five core services in a modular-monolith setup. Boundaries enforced through module structure and package namespaces, not network — microservice split only at a clear scaling bottleneck (no earlier than MVP 4).

- **AttestationService** — EAS adapter; takes validated schemas, writes on-chain, persists UID mappings in PostgreSQL.
- **SchemaRegistry** — CIRPASS-2 mapping layer; manages schema versions and off-chain JSON-schema validation.
- **StorageService** — dual-write to Filebase plus Arweave; encryption at rest with per-asset keys.
- **DIDService** — resolves did:web (HTTPS fetch plus caching) and did:pkh (deterministic compute).
- **RegistrySyncService** — EU Central DPP Registry connector; uses API webhooks for status changes; responsible for Backup DPP Service failover.

6.5 EUDI Wallet Integration

From 2027 EU member states must provide EUDI wallets. For industrial assets this becomes relevant primarily for (a) owner identification on ownership transfer and (b) institutional issuer authentication. Implementation via **OpenID4VCI** (issuance) and **OpenID4VP** (presentation) — the OpenID Foundation standards that are mandatory under EUDI. EBSI compatibility is preserved by using W3C VC 2.0 as the shared format.

7. Critical Flows

Three end-to-end flows define system behavior. Each is shown below as a sequence diagram and commented step by step.

7.1 Flow 1 — Asset Onboarding

From the moment an asset leaves the production line to the moment the DPP is live. Typically executed at the manufacturer (or OEM converter) as a batch — a production lot of 500 devices can be fully onboarded in under ten minutes.

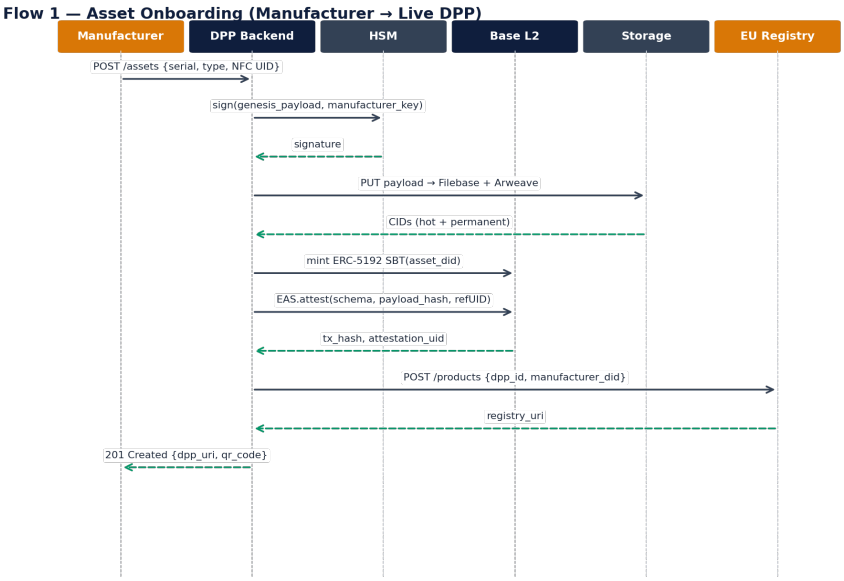

Figure 5 — Flow 1: asset onboarding.

Steps in detail:

1. **POST /v1/assets** — manufacturer system sends serial, type, and NFC UID. The NFC tag is physically applied to the asset, and its UID is known from production.
2. **HSM signature** — the manufacturer's private key (controlling the did:web) signs a GenesisAttestation (BOM, production date, CO_2 footprint). The key never leaves the HSM.
3. **Dual write to storage** — the full genesis payload (encrypted) is written to Filebase plus Arweave; CIDs are returned.
4. **ERC-5192 SBT mint** — on Base, a soulbound token is minted with the asset DID as token ID. The initial owner is the manufacturer wallet.
5. **EAS attestation** — the genesis attestation is written on Base with refUID=SBT_ID and schema=ManufactureAttestation.

6. **EU Registry record** — POST to the EU Central DPP Registry with DPP ID, manufacturer DID, DPP service URI, and backup service URI.
7. **QR code generation** — a GS1 Digital Link URL is returned for the label printing workflow. The NFC tag is programmed with the same URL.

7.2 Flow 2 — Calibration Event

The most frequent lifecycle event in the industrial context. Equipment calibration occurs typically one to four times per year per asset, depending on industry and standard. Workflow optimization is commercially critical here — if the calibration lab needs five minutes more per service than its existing PMS workflow, adoption fails. The architecture therefore integrates directly into the existing lab application rather than introducing a separate UI.

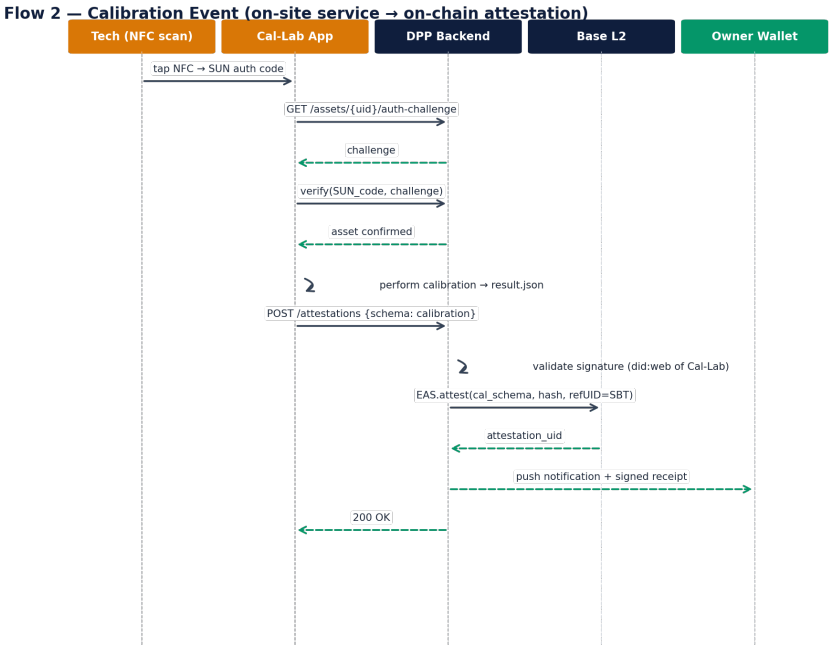

Figure 6 — Flow 2: calibration event (on-site service → on-chain attestation).

Anti-spoofing via SUN auth: The technician taps the NFC tag with their smartphone. The tag generates, via AES-128, a so-called SUN code (Secure Unique Number) — an authentication response that is unique per tap. The lab app sends this to the backend, which verifies against the chip UID and a rotating counter. This guarantees that a calibration was actually performed at the physical asset, not remotely and not with a cloned identifier.

7.3 Flow 3 — Verification

A verifier (insurer, market-surveillance inspector, B2B-resale buyer, auditor) scans the QR code or taps the NFC tag with a standard smartphone. The verifier app is **usable without an account** — important for market-surveillance inspectors who share devices.

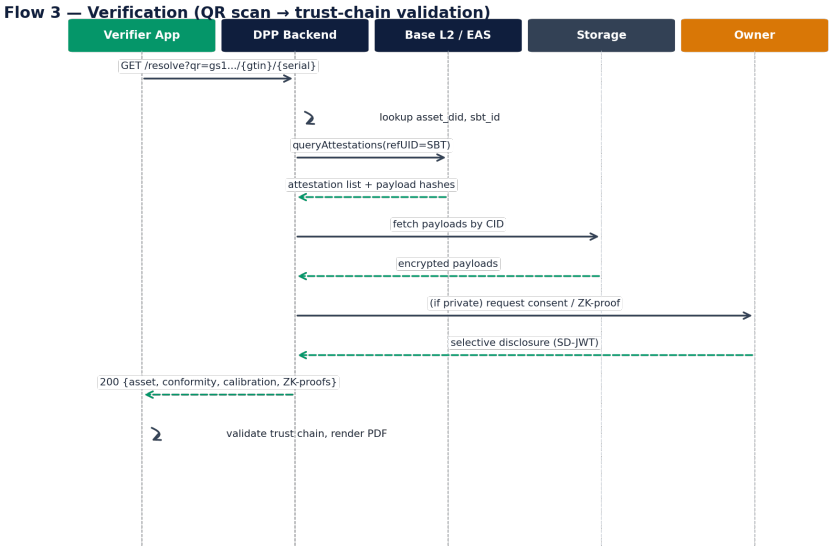

Figure 7 — Flow 3: verification (QR/NFC scan → trust chain validation).

Two modes depending on verifier need: (a) public resolution for non-sensitive data (manufacturer, model, conformity standard, calibration status valid or invalid without details); (b) selective-disclosure flow, which sends a consent request to the holder — the holder approves or denies in their wallet app within five seconds.

7.4 Flow 4 — Ownership Transfer

The ERC-5192 SBT is **permanently non-transferable** (soulbound). Ownership transfer is therefore implemented not by token transfer but by an OwnershipTransfer attestation. The current owner signs the transfer intent (from_did, to_did, asset_did); the new owner signs acceptance (co-signature pattern). The backend writes the attestation; the SBT remains at its original mint-address anchor. Ownership is subsequently determined exclusively by the most recent OwnershipTransfer attestation.

Why SBT despite ownership dynamics? Separation of identity (the asset exists) and ownership (who has it). If the SBT were transferable, the loss of an owner wallet would erase the entire asset-identity system. With the SBT as an identity anchor the asset remains reconstructible even if all previous owner wallets are lost — the next rightful owner can initiate a new OwnershipTransfer attestation through the manufacturer (or through the last documented owner).

7.5 Flow 5 — Decommission and Recycling

End-of-life: the accredited recycler scans the asset, documents recovered materials (for CO_2 reporting and circular-economy disclosure), and writes a DecommissionAttestation. After this step the SBT is marked “retired” (resolver-contract flag); further lifecycle attestations are rejected by the system. The asset history remains available for ten years (ESPR requirement); afterwards the per-asset encryption keys are destroyed (cryptographic deletion).

8. Security Architecture and GDPR

Two orthogonal concerns: cryptographic security (anti-clone, anti-spoof, anti-replay) and regulatory GDPR compliance. Both are addressed in this chapter.

8.1 Key Management

Issuer keys: manufacturer and lab keys live in cloud HSMs (AWS CloudHSM, Azure Key Vault Premium, or on-premise YubiHSM 2 for DACH-sovereign deployments). Keys never leave the HSM; signatures are requested via HSM API. Key rotation: annual, with did:web document update over HTTPS — old keys remain valid for historical-attestation verification.

Holder keys: Coinbase Smart Wallet with Passkey (WebAuthn/FIDO2). The key exists as a hardware-bound secure-enclave key on the smartphone, with no seed phrase. Wallet recovery is via Apple/Google cloud sync of the Passkey or via social recovery (3-of-5 trusted contacts). Smartphone loss without cloud backup: the asset identity remains intact (SBT anchor) but the owner must initiate a new OwnershipTransfer attestation through the manufacturer recovery path.

8.2 Anti-Cloning of the Trust Anchor

NTAG 424 DNA implements **Secure Dynamic Messaging (SDM)** with AES-128. On every tap the chip emits a cryptographically unique URL parameter that the backend validates against the chip UID and counter. The AES key is anchored in hardware and cannot be read out. Cloning attempts fail because a clone chip would carry the same UID but a different secret key — the SUN code would be invalid. **Known attack vector:** if an attacker has physical access to the asset and removes the tag, they can build a clone with offset UIDs, but this clone will not match the EU Registry or manufacturer records. Optional: tamper-evident encapsulation with a detector loop that sets an NTAG-internal tamper flag — fully irreversible.

8.3 GDPR Compliance Architecture

Where is personal data, really? In the B2B industrial use case most data is non-personal (asset data, calibration values, machine data). Personal data arises only at (a) owner identity (did:pkh plus recovery email or phone), (b) technician signature on a calibration certificate, (c) service-personnel data inside Repair attestations.

Pattern: Personal data is stored exclusively off-chain in encrypted storage; on chain only the hash and the encrypted pointer. Cryptographic deletion: on an Art. 17 request the per-person encryption key is destroyed, the encrypted blob remains persistent (Arweave is non-deletable) but is functionally inaccessible. This practice is marked as **tolerated by EDPB Guidelines 02/2025**, although not yet judicially confirmed.

Joint controllership: manufacturer, platform operator, and the EU Registry are potentially joint controllers. Before MVP 2, an Art. 26 joint-controller agreement template with standard contractual clauses for all issuer onboardings is required — to be drafted with the GDPR counsel in the founding team (see MVP 0 / founder hire).

8.4 Smart Contract Security

Three contracts: (a) **ERC-5192 SBT** — audited reference implementation, no custom code; (b) **EAS schemas and resolvers** — schemas are data only, resolvers carry our business logic (only accredited labs may write CalibrationAttestations); (c) **Registry-Update MultiSig** — 3-of-5 MultiSig for issuer-whitelist updates, so that no single founder compromise can compromise the system. **Audit plan:** external security audit (Trail of Bits, OpenZeppelin, or ChainSecurity DACH) before MVP 2 mainnet launch. Estimated budget: 50–100 k€.

8.5 Threat Model — Top 5 Risks

Threat	Vector	Mitigation
Tag clone	Physical access to asset, tag removed	NTAG AES-128, tamper-evident encapsulation, EU Registry cross-check
Wrong attestation	Compromised issuer (lab, manufacturer)	Accreditation whitelist on-chain, MultiSig updates, notified-body audit trail
Wallet loss	Smartphone lost with no backup	Social recovery, manufacturer recovery path via OwnershipTransfer
GDPR fine	On-chain PII through a bug	Schema validation before every write, periodic data-classification audits
Replay attack	SUN code is reused	Backend counter, replay detection with sliding window of one hour

9. Implementation Roadmap

Five MVPs over 30 months. Each MVP is a deliberate reduction: what is the absolute minimum that tests the phase's hypothesis?

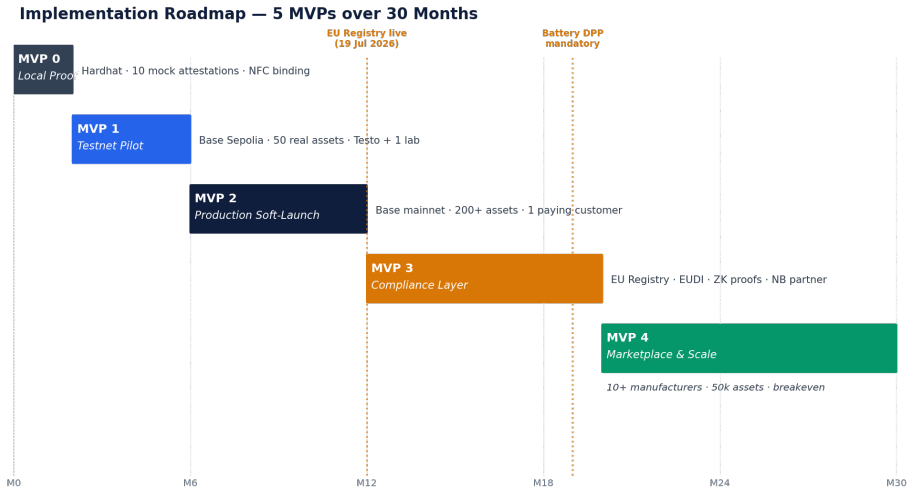

Figure 8 — Implementation roadmap with regulatory milestones.

9.1 MVP 0 — Local Proof (Months 0–2)

Hypothesis: The tech stack works end-to-end on Hardhat (local EVM) plus mock NFC tags.

- **Scope:** Hardhat-based EAS schema deployment, ERC-5192 mint, 10 mock attestations, manually programmed NTAG tags, locally hosted REST API.
- **Deliverables:** working local demo (CLI-driven), GitHub repository with IaC setup, technical engineering log.
- **Team:** 1 tech co-founder, David (domain plus product), freelance GDPR counsel at 20 percent FTE.
- **Budget:** bootstrapping; EXIST stipend application in preparation.

9.2 MVP 1 — Testnet Pilot (Months 2–6)

Hypothesis: A real calibration lab and a manufacturer can integrate the workflow into the existing process without friction.

- **Scope:** Base Sepolia deployment (testnet, free), Issuer Portal MVP (React, single-issuer), Owner Mobile App stub (display-only), Verifier web page with QR resolution.
- **Pilot partners:** Measurement company (cornerstone) plus one DAkkS-accredited calibration lab (external, LOI signed before MVP 0 ends).
- **Asset volume:** 50 real assets from a selected product line.
- **Funding:** Pre-Seed close — 0.75–1.5 M€ with HTGF as lead.

- **Team growth:** +1 backend engineer, +1 frontend engineer, +1 GDPR counsel (founding member, full-time).
- **Exit criterion:** lab uses the system without operator intervention; one insurer LOI signed in the industrial segment.

9.3 MVP 2 — Production Soft-Launch (Months 6–12)

Hypothesis: The system handles production load; a paying customer wires the first invoice.

- **Scope:** Base mainnet deployment, external security audit, full Owner Mobile App (iOS plus Android), Filebase + Arweave dual write, DPIA filed with Lower Saxony data-protection authority and accepted.
- **Scaling:** 200+ real assets, 2 manufacturers, 3 calibration labs.
- **First revenue:** 1 manufacturer API subscription (40–80 k€ per year) plus 1 insurer pilot contract.
- **Compliance:** European Blockchain Sandbox Cohort 4 application (if Cohort 3 missed); EIC Accelerator application submitted.
- **Exit criterion:** first 50 k€ ARR; burn rate under 120 k€ per month; clear path to Seed round.

9.4 MVP 3 — Compliance Layer (Months 12–20)

Hypothesis: The system is ESPR-compliant, EUDI-Wallet-compatible, and a notified body integrates us as a standard.

- **Scope:** EU Central DPP Registry integration (live from 19 July 2026), Backup DPP Service contract with a second provider, OIDC4VCI/VP endpoints for EUDI Wallet, ZK proof flows in production (calibration-validity proof as first live use case).
- **Partnership:** notified-body partnership with TÜV or DEKRA — they validate ConformityAttestations against our platform; significant trust marker for VCs and customers.
- **Scaling:** 5–10 manufacturers live, 1,000+ assets, first EU expansion (FR, IT, NL).
- **Funding:** EIC Accelerator decision (2.5 M€ grant plus up to 15 M€ equity option, 8 percent acceptance rate).
- **Exit criterion:** 10+ manufacturers in pipeline; ESPR compliance documented; Seed round prepared.

9.5 MVP 4 — Marketplace and Scale (Months 20–30)

Hypothesis: We are not only a compliance tool but a service marketplace, and unit economics are positive.

- **Scope:** calibration/service marketplace (Owner App: booking of calibration services), insurer integration with predictive-maintenance data feed, multi-vertical schema extension (lab equipment, medical devices).

- **Scaling:** 10+ manufacturers in production, 50,000+ assets, EU-wide expansion (DE, FR, IT, NL, ES, PL).
- **Funding:** Seed close 3–6 M€ — Bosch Ventures or Munich Re Ventures as lead, Cherry / Atlantic Labs as co-lead.
- **Operating metrics:** ARR run rate 3–8 M€, gross margin above 75 percent, customer concentration below 30 percent for top customer, logo retention above 95 percent.
- **Exit criterion:** Series A preparation; strategic M&A exploration initiated (industrial software incumbents, insurance majors).

10. Tech Stack Reference

Compact quick reference for CTO onboarding or technical investor due diligence.

Layer	Technology	Rationale
L2 Chain	Base (OP-Stack)	Lowest fees, native EAS, Coinbase Smart Wallet
Smart Wallet	Coinbase Smart Wallet	Passkey UX, no seed phrase, EIP-4337 native
Attestations	EAS (Ethereum Attestation Service)	Production-ready, token-free, composable
Identity Token	ERC-5192 (Soulbound)	Only SBT standard with real adoption
Credentials	W3C VC 2.0 (SD-JWT)	W3C-final 2025, EBSI/EUDI-compatible, selective disclosure
DID Methods	did:web (Issuer), did:pkh (Holder)	Pragmatic, no own method spec required
Hot Storage	Filebase (S3-API + IPFS)	0.06 USD/GB/month, 3x geo-redundant
Permanent Storage	Arweave + Bundlr	Pay-once, 20+ years guaranteed
ZK Circuits	Noir (Aztec)	Universal setup, no per-circuit ceremony
Mobile Prover	Mopro	2–8 seconds on modern smartphones
NFC Chip	NTAG 424 DNA (NXP)	AES-128 SUN, cryptographically anti-clone, 0.30–1.50 USD
Data Carrier	GS1 Digital Link (ISO/IEC 18975)	EU DPP standard, GS1 Resolver network
Backend	Node.js + TypeScript, PostgreSQL	Standard, large talent pool, fast hiring
Frontend Issuer	Next.js + Tailwind + shadcn/ui	Production-ready, fast iteration
Mobile Owner App	React Native + Expo	Cross-platform, Coinbase Smart Wallet SDK
HSM	AWS CloudHSM or YubiHSM 2	FIPS 140-2 Level 3, DACH-sovereign option
EU Registry Connector	Custom — once API spec is final	Implemented in MVP 3

Layer	Technology	Rationale
Auth (Issuer)	mTLS + DID-bound JWT	High trust, low throughput overhead
Auth (Holder)	WebAuthn / FIDO2 Passkey	Hardware-bound, phishing-resistant
Observability	OpenTelemetry + Grafana Cloud	Open standard, vendor-flexible

11. Open Technical Questions

Honest list of unknowns to be resolved before MVP 2 or 3. Each item has an owner profile and a recommended resolution date.

11.1 ERC-5192 Resale / Secondary Market

Industrial assets are traded on the B2B secondary market (equipment relocation, insolvency liquidation, second-life sales). The SBT is non-transferable. Planned solution: **wrapped-ownership pattern** — a separate transferable OwnershipNFT references the SBT. But this complicates the trust chain and requires custodian setups. **Owner:** tech co-founder plus smart-contract audit firm; **deadline:** before MVP 3.

11.2 EU Central Registry — Final API Spec

CIRPASS-2 consultation is ongoing. The spec is expected to be finalized in Q2 2026. Risk: schema misalignment with our attestation model. Mitigation: contribute to the CIRPASS-2 working group, or at minimum monitor the consultation actively. **Owner:** David as domain founder; **deadline:** before MVP 3 (Q4 2026).

11.3 Backup DPP Service — Partner and SLA

ESPR Art. 9 requires an independent backup provider. Options: (a) a commercial competitor (Spherity, Circularise) — politically problematic; (b) a state or cooperative solution (Bayern Innovativ, a VDMA backup service) — most likely path; (c) a multi-provider consortium analogous to EUDI. **Owner:** David plus legal co-founder; **deadline:** before MVP 3 go-live.

11.4 ZK Circuit Audit Cost

Noir uses a universal setup, eliminating ceremony costs. But every custom circuit (CalibrationValidityProof, OwnershipProof, AccreditationProof) requires a separate audit. Market price: 30–80 k€ per circuit. With three to five circuits this comes to 100–400 k€ — substantial. **Mitigation:** as few custom circuits as possible; reuse of existing Aztec/Noir reference circuits where feasible. **Owner:** tech co-founder; **deadline:** budget plan before Seed round.

11.5 Smart Wallet Migration

Coinbase Smart Wallet is the best UX option today, but vendor-lock risk is non-zero. EIP-4337 is the standard, but smart-wallet implementations diverge in detail (recovery, session keys). Worst-case migration: three to six months of engineering. **Mitigation:** wallet-abstraction layer in the Owner App code; all wallet-specific calls go through an interface tested against Coinbase, Privy, and Web3Auth.

11.6 GS1 License Cost at Scale

GS1 Digital Link requires a GS1 Company Prefix license (DACH: GS1 Germany, approximately 280 € per year plus volume fees). At 100,000+ asset volumes per year per manufacturer GS1 costs become relevant. **Mitigation:** license held by the manufacturer, not by us — manufacturers typically already hold their own GS1 prefixes. We consume their GS1 identifiers as pass-through.

11.7 Multi-Chain vs. Base-Only

Strategic question: single chain for simplicity, or multi-chain (Base + Polygon + Optimism) for resilience? A multi-chain setup triples operational complexity (separate RPCs, separate indexers, separate smart contracts). Recommendation: Base-only until MVP 4, then multi-chain as disaster-recovery preparation, not for geographic routing.

Appendix A — Cost Model per Asset Lifecycle

An asset lifecycle comprises 1 ManufactureAttestation, 0–2 ConformityAttestations, 5–10 CalibrationAttestations (10 years × roughly one per year), 1–3 RepairAttestations, 0–3 OwnershipTransfers, 1 DecommissionAttestation. Assumption for modeling: 12 attestations across the lifetime.

Cost component	Unit cost	Per asset (12 attest.)	Per 50k assets
Base L2 gas (EAS attest)	0.02 USD/attest	0.24 USD	12,000 USD
Base L2 gas (SBT mint)	0.05 USD/asset	0.05 USD	2,500 USD
Filebase (50 MB lifetime)	0.003 USD/MB-yr	0.15 USD	7,500 USD
Arweave (50 MB permanent)	0.007 USD/MB	0.35 USD	17,500 USD
GS1 + NFC tag (HW)	0.80 USD/asset	0.80 USD	40,000 USD (one-time)
Total software costs		**0.79 USD**	**~39,500 USD/yr**

Interpretation: At 50,000 assets per year in the scale scenario (MVP 4), recurring infrastructure costs are under 40,000 USD annually, plus one-time hardware costs of 40,000 USD for the tags. Compared with server hosting (1,500–3,000 USD per month), application engineering (team costs), and compliance-audit budgets (50–150 k€ per year) these numbers are negligible — which justifies the stack choice.